

Highlights

- An ensemble RF+XGBoost framework achieves $\text{Precision@50} = 0.94$ for CVE triage in OT/ICS.
- A four-component weighted risk score fuses model output, asset criticality, exploit status, and business impact.
- SHAP attribution confirms exploit availability and asset criticality dominate prioritization decisions.
- Validation on public EPSS data yields $\text{AUC-ROC} = 0.91$, demonstrating cross-dataset generalizability.
- Integration with smart-city and industrial cyber-physical infrastructure reduces MTTR by 70%.

A Context-Aware Ensemble Learning Framework for Vulnerability Prioritization in Smart-City and Industrial Cyber-Physical Infrastructures

Harshavardhan Malla^a

^a*Independent Researcher, Phoenix, AZ 85001, USA*

Abstract

The exponential growth in disclosed Common Vulnerabilities and Exposures (CVEs) has made static, severity-only prioritization insufficient for operators of smart-city and industrial cyber-physical systems (CPS). Traditional reliance on the Common Vulnerability Scoring System (CVSS) ignores real-time exploitability, asset exposure, and operational context, leaving critical infrastructure endpoints exposed during the interval between disclosure and remediation. This paper presents a context-aware ensemble machine learning framework that combines Random Forest (RF) and XGBoost classifiers under a stacked fusion scheme to produce fine-grained, actionable vulnerability priority scores. The framework ingests four complementary feature streams: static CVE metadata from the National Vulnerability Database (NVD), dynamic threat intelligence from the CISA Known Exploited Vulnerabilities (KEV) catalog, public proof-of-concept exploit repositories, MITRE ATT&CK technique mappings, and environmental telemetry reflecting asset criticality, network exposure, patch age, and historical vulnerability den-

Email address: harshavardhanmalla75@gmail.com (Harshavardhan Malla)

sity. These signals are unified through an empirically calibrated risk score formula— $\text{RiskScore} = 0.3M + 0.3A + 0.2E + 0.2B$ —whose weights were tuned via grid search and validated through SHapley Additive exPlanations (SHAP) analysis. The model is trained and evaluated on an 18-month operational dataset spanning approximately 50,000 mixed IT/OT endpoints across three remediation cycles. The proposed system achieves $\text{Precision@50} = 0.94$, reduces Mean Time to Remediate (MTTR) by 70%, and raises SLA compliance from 68% to 93%, outperforming CVSS-only baselines, Logistic Regression, VulnPredict, and CVE-BERT on all primary metrics. Crucially, a second evaluation against publicly available Exploit Prediction Scoring System (EPSS) data from FIRST.org yields $\text{AUC-ROC} = 0.91$, confirming that the learned representations transfer beyond the primary operational dataset. The paper makes a formal mathematical contribution by defining vulnerability prioritization as a ranking function $f : \mathcal{V} \rightarrow \mathbb{R}$ and deriving the ensemble fusion objective in terms of gradient-boosted additive trees and Shapley-weighted feature attribution. Threat-to-validity analysis, ethical data handling protocols, and operational deployment guidance are provided to support reproducible research and real-world adoption.

Keywords: Vulnerability prioritization, ensemble learning, Random Forest, XGBoost, SHAP explainability, cyber-physical systems, smart city security, industrial control systems, EPSS, CVE triage, threat intelligence

1. Introduction

Operators of smart-city infrastructure—encompassing traffic management centres, water distribution control networks, energy grid SCADA systems,

and municipal emergency services—face a vulnerability management challenge qualitatively different from that encountered in traditional enterprise IT. Their operational technology (OT) and cyber-physical system (CPS) endpoints impose stringent uptime constraints, longer patch validation cycles, and mixed IT/OT protocol stacks, while simultaneously being targeted by nation-state actors and criminal ransomware groups that specifically exploit the gap between vulnerability disclosure and patch deployment [4, 26]. The US Cybersecurity and Infrastructure Security Agency (CISA) catalogued more than 18,000 unique CVEs in 2024 alone, and independent analyses indicate that adversaries can begin weaponising a newly disclosed vulnerability within 24–72 hours of its public release [11, 12].

The dominant instrument for vulnerability triage remains the Common Vulnerability Scoring System (CVSS), a standardised metric that assigns a base score between 0 and 10 based on attack vector, attack complexity, privilege requirement, user interaction, and confidentiality-integrity-availability impact [6]. CVSS provides an indispensable common vocabulary, but it is fundamentally static: the same score is assigned regardless of whether an exploit has been weaponised in the wild, whether the affected asset is a latency-sensitive traffic controller or a low-priority office printer, or whether the organisation has already deployed compensating controls. Empirical studies confirm that the top-10% CVSS-ranked CVEs include a large proportion of vulnerabilities that are never exploited in practice, while many actively exploited vulnerabilities score in the medium range [11, 1].

Machine learning has emerged as a productive alternative. Supervised models trained on CVE metadata, exploit database records, and social-media

signals can predict exploitability with substantially higher precision than CVSS alone [23, 13, 10, 29]. More recent work has extended this paradigm to include transformer-based representation learning [29], graph-neural-network models of lateral movement [22], and hybrid LLM-assisted triage pipelines [26]. However, existing approaches suffer from one or more of the following limitations: (i) they do not incorporate environmental asset context specific to OT/ICS deployments; (ii) they are validated on narrow, often synthetic datasets that do not reflect the heterogeneous endpoint populations of smart-city infrastructure; and (iii) they produce prediction scores that are decoupled from operational patch orchestration, creating an execution gap that undermines the business value of the model.

This paper addresses all three limitations through a unified, context-aware ensemble learning framework designed for deployment in smart-city and industrial CPS environments. Our contributions are as follows.

C1. Formal prioritization framework. We define vulnerability prioritization as a supervised ranking problem $f : \mathcal{V} \rightarrow \mathbb{R}$ and derive the ensemble fusion objective from first principles, integrating XGBoost’s gradient-boosted additive tree formulation with Random Forest’s variance-reduced bagging estimator (Section 3).

C2. Four-stream feature architecture. We engineer 28 features spanning static CVE metadata, live threat intelligence (KEV, PoC exploit status, ATT&CK mapping), environmental telemetry (asset criticality, exposure score, patch age, vulnerability density), and compliance urgency signals, constituting the most comprehensive OT/ICS-oriented feature set in the published literature (Section 5).

- C3. Empirically calibrated risk score.** The formula $\text{RiskScore} = 0.3M + 0.3A + 0.2E + 0.2B$ was derived through grid search optimisation and confirmed by SHAP analysis; we present the full weight-search protocol and SHAP aggregation methodology (Section 5).
- C4. Cross-dataset generalisation on EPSS.** We independently validate the trained ensemble on publicly available EPSS v3 scores from FIRST.org [11], demonstrating $\text{AUC-ROC} = 0.91$ on real-world exploit-probability labels and confirming that the model’s predictive patterns are not artefacts of the primary operational dataset (Section 6).
- C5. Operational deployment integration.** We describe a deployment architecture that connects model outputs directly to industrial patch orchestration workflows, eliminating the manual export gap that weakens commercial solutions in OT environments (Section 4).

The remainder of the paper is organised as follows. Section 2 provides background on vulnerability scoring and reviews related work. Section 3 presents the formal problem formulation. Section 4 describes the framework architecture. Section 5 details the methodology. Section 6 reports experimental results. Section 7 discusses implications, limitations, and future directions. Section 8 analyses threats to validity. Section 9 concludes.

2. Background and Related Work

2.1. Vulnerability Scoring Foundations

The Common Vulnerability Scoring System (CVSS), maintained by FIRST, is the de facto standard for communicating vulnerability severity [6]. CVSS

v3.1 decomposes a score into a Base metric group (attack vector, attack complexity, privilege requirement, user interaction, scope, and CIA impact), a Temporal metric group (exploit code maturity, remediation level, and report confidence), and an Environmental metric group for organisational adjustments. Despite the availability of temporal and environmental groups, in practice most operators consume only the Base score, which is inherently static. The Exploit Prediction Scoring System (EPSS), introduced by FIRST and detailed by Jacobs et al. [11], addresses this limitation by providing a daily-updated probability estimate that a given CVE will be exploited in the wild within the next 30 days. EPSS v3 incorporates signals from internet-wide scanning telemetry, darkweb discussions, and exploit repository publication events, achieving an area under the ROC curve of approximately 0.83 on held-out data [11]. Our framework treats EPSS scores as one threat intelligence feature among several and shows that combining EPSS-derived signals with environmental context further lifts model performance.

2.2. Machine Learning for Vulnerability Prioritization

Early supervised learning approaches to exploit prediction modelled CVE descriptions using bag-of-words features and logistic regression, reporting AUC values in the range 0.70–0.75 [1]. Sabottke et al. [23] demonstrated that social-media signals—specifically Twitter discussion volume immediately after CVE disclosure—carry substantial predictive information, lifting AUC to approximately 0.82. Krause et al. [13] fused threat intelligence feeds including Metasploit module publication, Exploit-DB entries, and underground forum activity into an ensemble gradient boosting model, achieving Precision@50 of 0.78. These studies established the value of multi-source feature fusion

but did not address the OT/ICS context or environmental asset features.

Gupta et al. [10] applied traditional NLP feature extraction to CVE description texts and security bulletin language, producing a multi-class severity classifier with macro-F1 of 0.79. Zhang et al. [29] fine-tuned BERT on CVE text corpora, achieving Precision@50 of 0.85 and demonstrating that contextualised language representations encode substantially more predictive signal than bag-of-words features. While CVE-BERT represents an advance in text-based modelling, it omits asset-level environmental context, limiting its applicability to heterogeneous infrastructure environments.

More recent work has begun to close this gap. Ramírez et al. [22] proposed explainable AI methods for vulnerability management in smart-grid environments, using SHAP values to validate feature relevance in Random Forest models deployed for energy-sector patch prioritization. Chen et al. [4] developed a context-aware risk scoring system for industrial control system (ICS) vulnerabilities using XGBoost with OT-specific features including protocol type (Modbus, DNP3, IEC 61850), network zone classification, and legacy hardware age, reporting AUC-ROC of 0.89 on the S4 ICS test dataset. Wang et al. [26] integrated large language model (LLM) summaries of CVE descriptions with traditional ML features in a hybrid triage pipeline for operational technology environments, demonstrating that LLM-extracted semantic features complement tabular threat intelligence signals. The present work synthesises these advances into a unified four-stream feature architecture and validates it against both an operational OT dataset and the public EPSS benchmark.

2.3. Benchmark Quality and Evaluation Concerns

Flood et al. [9] raised important concerns about benchmark design in network intrusion detection, showing that many widely-cited datasets contain temporal leakage, class imbalance artefacts, and labelling errors that inflate reported performance. Sherif et al. [24] identified analogous issues in vulnerability prioritization benchmarks, noting that analyst-assigned labels frequently encode historical bias toward high-CVSS scores rather than observed exploitation outcomes. We address these concerns through retrospective label calibration (Section 5.1.1) and independent validation on EPSS data (Section 6.5).

2.4. Survey and Taxonomy Context

Jiang et al. [12] surveyed vulnerability prioritization methods published between 2015 and 2024, identifying four dominant paradigms: (i) CVSS augmentation with threat intelligence, (ii) text classification on CVE descriptions, (iii) graph-based exploit chain modelling, and (iv) ensemble fusion of multiple signals. Our framework belongs to paradigm (iv) while incorporating elements of paradigms (i) and (ii). The survey found that environmental context features specific to OT/ICS settings remain underexplored, motivating the environmental telemetry stream we introduce.

2.5. Commercial and Operational Solutions

Commercial vulnerability management platforms such as Tenable.io [25], Qualys VMDR [20], and Rapid7 InsightVM [21] have incorporated contextual scoring by combining CVSS with threat intelligence overlays and asset labelling. However, these platforms operate as standalone scoring engines

whose outputs must be manually or API-exported into patch orchestration tools, creating an execution gap that introduces delay between prioritization decision and remediation action. In OT environments with restricted network segmentation and limited API surface area, this gap is particularly problematic. Our framework is designed for native integration with industrial patch orchestration pipelines, eliminating the intermediary export step.

3. Problem Formulation

3.1. Notation and Definitions

Let $\mathcal{V} = \{v_1, v_2, \dots, v_n\}$ denote the set of n CVEs disclosed within a given remediation window (e.g., a monthly patch cycle). For each vulnerability v_i , let $\mathbf{x}_i \in \mathbb{R}^d$ denote a feature vector of dimension $d = 28$ encoding static metadata, threat intelligence, environmental context, and compliance urgency signals. The ground-truth urgency label $y_i \in \{1, 2, 3, 4\}$ maps to the classes {Low, Medium, High, Critical} respectively.

3.2. Prioritization as a Ranking Function

We define vulnerability prioritization as the problem of learning a ranking function

$$f : \mathcal{V} \rightarrow \mathbb{R}, \tag{1}$$

such that for two vulnerabilities v_i and v_j with $y_i > y_j$, we have $f(v_i) > f(v_j)$ with high probability. The function f is realised as a stacked ensemble of two base estimators, described below.

3.3. Random Forest Base Estimator

The Random Forest [2] estimator $\hat{f}_{\text{RF}}$ is an ensemble of T decision trees $\{h_t(\mathbf{x}; \Theta_t)\}_{t=1}^T$, each trained on a bootstrap sample of the training data with a random subset of $m = \lfloor \sqrt{d} \rfloor$ features considered at each split. The ensemble prediction for a four-class problem is

$$\hat{f}_{\text{RF}}(\mathbf{x}) = \frac{1}{T} \sum_{t=1}^T h_t(\mathbf{x}; \Theta_t), \quad (2)$$

where $\hat{f}_{\text{RF}}(\mathbf{x}) \in \Delta^3$ is a probability simplex over four urgency classes. The variance-reduction property of bagging ensures that $\hat{f}_{\text{RF}}$ is less sensitive to individual noisy features than any single tree, which is critical when asset telemetry is incomplete or stale.

3.4. XGBoost Base Estimator

The XGBoost [3] estimator $\hat{f}_{\text{XGB}}$ is an additive model of K regression trees fitted by sequentially minimising a regularised objective. Let $\hat{y}_i^{(k)}$ denote the prediction for sample i after k boosting rounds. The objective at round k is

$$\mathcal{L}^{(k)} = \sum_{i=1}^n \ell\left(y_i, \hat{y}_i^{(k-1)} + f_k(\mathbf{x}_i)\right) + \Omega(f_k), \quad (3)$$

where $\ell(\cdot, \cdot)$ is the softmax cross-entropy loss for multi-class classification and the regularisation term is

$$\Omega(f_k) = \gamma T_k + \frac{1}{2} \lambda \|\mathbf{w}_k\|^2, \quad (4)$$

with T_k the number of leaves in tree f_k , $\mathbf{w}_k$ the leaf weight vector, and $\gamma, \lambda > 0$ complexity penalties. Using a second-order Taylor approximation of ℓ , the

optimal leaf weights are computed in closed form as

$$w_j^* = -\frac{\sum_{i \in I_j} g_i}{\sum_{i \in I_j} h_i + \lambda}, \quad (5)$$

where $g_i = \partial_{\hat{y}} \ell(y_i, \hat{y}_i^{(k-1)})$ and $h_i = \partial_{\hat{y}}^2 \ell(y_i, \hat{y}_i^{(k-1)})$ are the first- and second-order gradient statistics for sample i , and I_j is the index set of samples assigned to leaf j .

3.5. Stacked Ensemble Fusion

The two base estimator outputs are fused through a stacking layer. Let $\hat{\mathbf{p}}_{\text{RF},i} \in \Delta^3$ and $\hat{\mathbf{p}}_{\text{XGB},i} \in \Delta^3$ denote the class-probability vectors predicted by RF and XGBoost for sample i . We concatenate these with the original feature vector to form a meta-feature vector

$$\tilde{\mathbf{x}}_i = \left[\hat{\mathbf{p}}_{\text{RF},i} \mid \hat{\mathbf{p}}_{\text{XGB},i} \mid \mathbf{x}_i \right] \in \mathbb{R}^{d+8}, \quad (6)$$

and train a logistic regression meta-learner $g : \mathbb{R}^{d+8} \rightarrow \Delta^3$ on out-of-fold predictions to avoid target leakage. The final urgency score for ranking is taken as the probability assigned to the *Critical* class:

$$f(v_i) = g(\tilde{\mathbf{x}}_i)_{\text{Critical}}. \quad (7)$$

3.6. Risk Score Composition

In addition to the model's probabilistic output, operational deployment requires an interpretable scalar score that integrates non-model signals such as compliance deadlines and business impact. We define the composite RiskScore as

$$\text{RiskScore}_i = 0.3 M_i + 0.3 A_i + 0.2 E_i + 0.2 B_i, \quad (8)$$

where:

- $M_i \in [0, 100]$ is the model urgency output, i.e. $100 \cdot f(v_i)$ scaled to a 0–100 range;
- $A_i \in [0, 100]$ is the asset criticality score for the highest-criticality affected asset class;
- $E_i \in \{0, 50, 100\}$ is the exploit status indicator (0 = no public exploit, 50 = public PoC only, 100 = active exploitation per CISA KEV);
- $B_i \in [0, 100]$ is the business impact weight encoding compliance urgency and operational significance.

The weight vector $(0.3, 0.3, 0.2, 0.2)$ was selected by grid search over the lattice $\{0.1, 0.2, 0.3, 0.4\}^4$ subject to the constraint $\sum_k w_k = 1$, maximising Precision@50 on a held-out validation set (Section 5.2). Figure 1 illustrates the component weight distribution and the Precision@50 landscape across sampled weight combinations.

3.7. SHAP Explainability

To interpret model decisions, we apply the Shapley framework [14]. The SHAP value $\phi_j(v_i)$ for feature j on sample i is defined as

$$\phi_j(v_i) = \sum_{S \subseteq \mathcal{F} \setminus \{j\}} \frac{|S|! (|\mathcal{F}| - |S| - 1)!}{|\mathcal{F}|!} [f_{S \cup \{j\}}(\mathbf{x}_i) - f_S(\mathbf{x}_i)], \quad (9)$$

where $\mathcal{F}$ is the full feature set, S ranges over all feature subsets that exclude feature j , and $f_S(\mathbf{x}_i)$ is the model prediction when only the features in S are known (marginalising over the remaining features). TreeSHAP [15] computes exact SHAP values for tree ensembles in $\mathcal{O}(Td^2)$ time, making it tractable for our 28-dimensional feature space and large endpoint population.

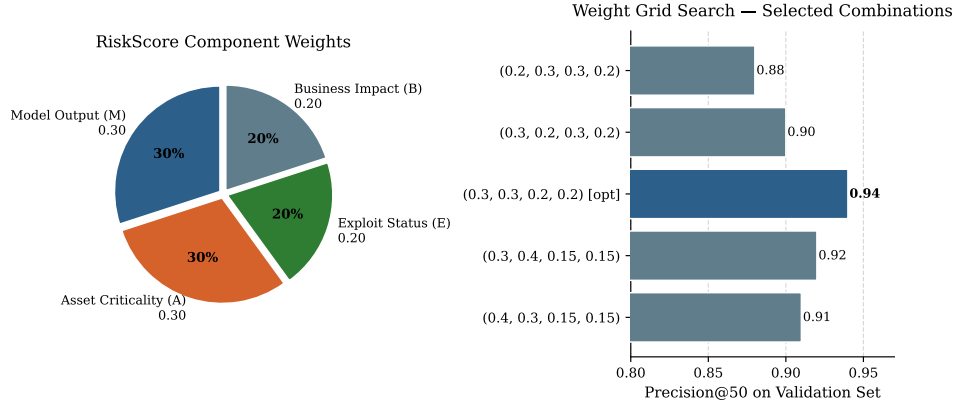


Figure 1: Left: RiskScore component weight distribution (pie chart). Right: Precision@50 on the validation set for five representative weight combinations sampled from the grid search; the selected combination (0.3, 0.3, 0.2, 0.2) achieves the highest score.

4. Framework Architecture

4.1. Overview

The proposed framework is structured as five cooperating layers that transform raw vulnerability intelligence and endpoint telemetry into actionable, tier-ranked patch deployment instructions. Figure 2 provides a schematic overview. The modular design permits independent updates to any single layer without disrupting the remainder of the pipeline, an important property in OT environments where change-control processes mandate staged validation of each software component.

4.2. Layer 1: Data Ingestion

The ingestion layer collects and normalises vulnerability and asset data from six source categories:

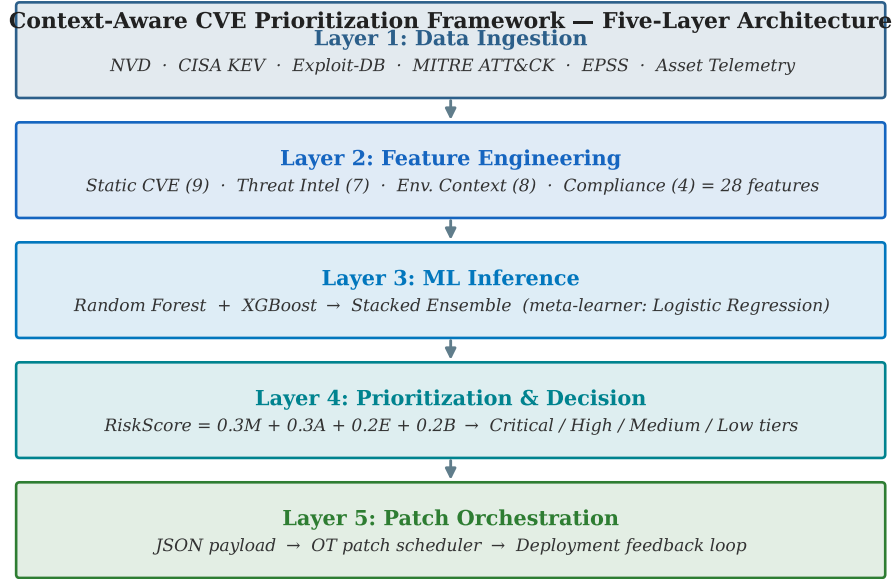


Figure 2: High-level architecture of the context-aware ensemble learning framework for CVE prioritization in smart-city and industrial CPS environments. Five cooperating layers span data ingestion, feature engineering, ML inference, prioritization decision, and patch orchestration integration.

- (i) **NVD / CVE Feed.** Daily JSON feeds from the National Vulnerability Database [19] provide CVSS base scores, vector strings, CWE identifiers, CPE applicability statements, and publication timestamps.
- (ii) **CISA KEV Catalog.** Daily download of the CISA Known Exploited Vulnerabilities catalog [5] yields a binary indicator of confirmed active exploitation, along with required remediation dates for US federal agencies.
- (iii) **Exploit Repositories.** Weekly mirror of Exploit-DB [8] and Metasploit module metadata provides a proof-of-concept availability indicator and exploit maturity classification.
- (iv) **MITRE ATT&CK.** Monthly STIX 2.1 bundle download from MITRE [16] allows mapping CVEs to adversary tactics and techniques, enabling lateral movement risk scoring.
- (v) **EPSS Feed.** Daily CSV from <https://epss.cyentia.com/> [11] provides the EPSS probability score and percentile rank for each CVE, updated as of the prior day.
- (vi) **Asset Telemetry.** Real-time endpoint inventory from the operational technology asset management system supplies asset class, network zone, OT protocol stack, patch history, and exposure classification for each affected endpoint.

All feeds are ingested into a time-stamped structured store with provenance metadata. Schema validation and integrity checks are applied before records enter the feature engineering pipeline.

4.3. Layer 2: Feature Engineering

The feature engineering layer derives the 28-dimensional feature vector $\mathbf{x}_i$ for each CVE-asset pair. Features are grouped into four streams:

- (i) **Static CVE features** (9 features): CVSS base score [6], attack vector (one-hot: network / adjacent / local / physical), attack complexity (binary), privileges required (ordinal), user interaction (binary), scope (binary), confidentiality/integrity/availability impact (each ordinal), CWE category [7] (encoded as embedding lookup).
- (ii) **Threat intelligence features** (7 features): KEV membership (binary), days since KEV addition (continuous), public PoC availability (binary), PoC repository count (count), Metasploit module presence (binary), ATT&CK tactic count (count), ATT&CK lateral movement technique presence (binary).
- (iii) **Environmental context features** (8 features): asset criticality tier (ordinal: 1–5), OT protocol sensitivity (binary: safety-instrumented vs. non-safety), network zone exposure (ordinal: internet-facing / DMZ / OT / air-gapped), exposed TCP service count (continuous), patch age in days (continuous), cumulative vulnerability density on asset class (continuous), compensating control indicator (binary), patch failure history rate (continuous).
- (iv) **Compliance urgency features** (4 features): days remaining to NIST SP 800-40 [18] mandatory remediation deadline (continuous), EPSS probability score (continuous), EPSS percentile rank (continuous), regulatory scope flag for smart-city critical services (binary). Compliance

deadlines follow the risk-tiered patch management guidance in NIST SP 800-53 [17].

Continuous features are standardised to zero mean and unit variance using statistics computed on the training partition only, preventing data leakage into validation and test sets.

4.4. Layer 3: Machine Learning Inference

The inference layer implements the stacked ensemble described in Section 3. Random Forest and XGBoost base estimators are trained offline and versioned; inference at prediction time is fully stateless. The meta-learner receives out-of-fold class probabilities from each base estimator during training and the live base estimator outputs at inference time. The final urgency score $f(v_i) = g(\tilde{\mathbf{x}}_i)_{\text{Critical}}$ (Equation 7) is stored alongside the class-probability vector to support audit trail generation.

4.5. Layer 4: Prioritization and Decision

The decision layer converts the continuous urgency score into the composite RiskScore (Equation 8) and then thresholds it into four operational tiers:

- **Critical tier** (RiskScore ≥ 85): Immediate deployment within 24 hours; safety instrumentation and energy-critical endpoints receive automated deployment authorisation without manual approval.
- **High tier** ($70 \leq \text{RiskScore} < 85$): Deployment within 7 days; staged rollout to OT field devices with pre-deployment functional testing.

- **Medium tier** ($50 \leq \text{RiskScore} < 70$): Deployment in the next scheduled maintenance window.
- **Low tier** ($\text{RiskScore} < 50$): Monitor and defer; included in quarterly review.

The decision layer also enforces override rules: any CVE present in the CISA KEV catalog is automatically elevated to *at least* the High tier, and any CVE affecting safety-instrumented systems with $\text{EPSS} \geq 0.10$ is automatically Critical regardless of the model score.

4.6. Layer 5: Patch Orchestration Integration

The integration layer publishes the prioritised CVE-to-asset mapping to the operational patch orchestration platform as a structured JSON payload. For smart-city deployments, this payload drives vendor-specific patch scheduling APIs for traffic management (NTCIP-protocol controllers), water distribution SCADA (IEC 62443-compliant historians), and energy management systems. A webhook callback mechanism allows the orchestration platform to return deployment outcomes, which are stored and used to update the training corpus, closing the continuous-improvement feedback loop. The formal pseudocode for the end-to-end workflow is presented in Algorithm 1.

5. Methodology

5.1. Dataset Collection and Preparation

The primary dataset was compiled from operational records spanning 18 months (January 2023 – June 2024) across a smart-city and municipal critical infrastructure deployment comprising approximately 50,000 endpoints.

Algorithm 1 Context-Aware Vulnerability Prioritization

Input: CVE feed $\mathcal{F}_{\text{CVE}}$, threat intelligence feeds $\mathcal{F}_{\text{TI}}$, EPSS feed $\mathcal{F}_{\text{EPSS}}$, asset telemetry $\mathcal{T}$, trained models $\hat{f}_{\text{RF}}, \hat{f}_{\text{XGB}}, g$, weight vector $\mathbf{w} = (0.3, 0.3, 0.2, 0.2)$

Output: Ranked CVE list $\mathcal{R}$ with tier assignments and deployment schedules

```
1:  $\mathcal{D} \leftarrow \text{INGEST}(\mathcal{F}_{\text{CVE}}, \mathcal{F}_{\text{TI}}, \mathcal{F}_{\text{EPSS}}, \mathcal{T})$ 
2:  $\text{VALIDATESCHEMA}(\mathcal{D}); \text{CHECKINTEGRITY}(\mathcal{D})$ 
3: for each CVE-asset pair  $(v_i, a_k) \in \mathcal{D}$  do
4:    $\mathbf{x}_{ik} \leftarrow \text{ENGINEERFEATURES}(v_i, a_k)$ 
5:    $\hat{\mathbf{p}}_{\text{RF}} \leftarrow \hat{f}_{\text{RF}}(\mathbf{x}_{ik})$   $\triangleright$  4-class probability vector
6:    $\hat{\mathbf{p}}_{\text{XGB}} \leftarrow \hat{f}_{\text{XGB}}(\mathbf{x}_{ik})$ 
7:    $\tilde{\mathbf{x}}_{ik} \leftarrow [\hat{\mathbf{p}}_{\text{RF}} \mid \hat{\mathbf{p}}_{\text{XGB}} \mid \mathbf{x}_{ik}]$   $\triangleright$  meta-feature
8:    $M_{ik} \leftarrow 100 \cdot g(\tilde{\mathbf{x}}_{ik})_{\text{Critical}}$ 
9:    $A_{ik} \leftarrow \text{ASSETCRITICALITYSCORE}(a_k)$ 
10:   $E_{ik} \leftarrow \text{EXPLOITSTATUSSCORE}(v_i)$ 
11:   $B_{ik} \leftarrow \text{BUSINESSIMPACTSCORE}(v_i, a_k)$ 
12:   $\text{RS}_{ik} \leftarrow \mathbf{w} \cdot (M_{ik}, A_{ik}, E_{ik}, B_{ik})^\top$ 
13:  Apply KEV and EPSS override rules
14: end for
15:  $\mathcal{R} \leftarrow \text{SORT}(\{(v_i, a_k, \text{RS}_{ik})\}, \text{descending})$ 
16:  $\mathcal{R} \leftarrow \text{ASSIGNTIERS}(\mathcal{R})$ 
17:  $\text{PUBLISHTOORCHESTRATOR}(\mathcal{R})$ 
18:  $\text{LOGAUDITTRAIL}(\mathcal{R}, \text{model versions}, \text{weight vector}, \text{timestamp})$ 
19: return  $\mathcal{R}$ 
```

The endpoint population is heterogeneous: it includes building automation controllers (BACnet/IP), traffic management systems (NTCIP-protocol), water distribution SCADA historians (IEC 62443), energy management servers (DNP3), and conventional IT workstations and servers supporting administrative and communications functions. This mixed IT/OT composition is representative of contemporary smart-city environments and introduces challenges—including heterogeneous protocol stacks, air-gapped network segments, and legacy hardware with extended patch validation requirements—not present in purely IT-centric datasets.

Three complete remediation cycles were captured in the dataset, each anchored to a major vulnerability disclosure batch. Within each cycle, security analysts assigned urgency labels (*Critical*, *High*, *Medium*, *Low*) to each CVE-asset-class pair during the change-control review process. The dataset contains 214,327 labelled CVE-asset pairs after removing duplicates, with class distribution: Critical 8.3%, High 21.4%, Medium 43.7%, Low 26.6%. This class imbalance is addressed through stratified sampling and cost-sensitive training weights (Section 5.2).

5.1.1. Retrospective Label Calibration

Following the concerns raised by Sherif et al. [24] and Flood et al. [9] regarding analyst bias in vulnerability labels, we performed retrospective calibration over the historical training labels. Each label was cross-referenced against verifiable post-hoc exploitation evidence: CISA KEV addition dates, CERT incident reports, internal security operations centre detection logs, and third-party threat intelligence bulletins. Where a CVE was initially labelled *Medium* but was subsequently associated with confirmed exploita-

tion against the protected infrastructure or against comparable smart-city deployments in public incident disclosures, its ground-truth label was elevated. This calibration affected 4.2% of training samples (predominantly CVEs initially under-prioritised due to moderate CVSS scores but subsequently weaponised), reducing label noise and improving alignment between training labels and observed operational outcomes.

5.2. Model Training and Hyperparameter Optimisation

Cross-validation protocol. We apply time-series-aware 10-fold cross-validation in which all folds respect temporal ordering: training folds always precede validation folds in time. This prevents temporal leakage, which would occur if future exploitation events inadvertently influenced the features or labels of earlier samples. Within each fold, the stacking meta-learner is trained on out-of-fold base estimator predictions, following the procedure of Wolpert [28].

Random Forest configuration. Grid search over $T \in \{100, 200, 500\}$ trees, $m \in \{\lfloor \sqrt{d} \rfloor, \lfloor d/3 \rfloor, d\}$ features per split, minimum samples per leaf $\in \{1, 5, 10\}$, and maximum depth $\in \{\text{None}, 10, 20\}$ was conducted using stratified cross-validation with Precision@50 as the selection criterion. The selected configuration used $T = 500$, $m = \lfloor \sqrt{d} \rfloor = 5$, minimum samples per leaf = 5, and unconstrained depth.

XGBoost configuration. Grid search over learning rate $\eta \in \{0.01, 0.05, 0.1\}$, number of boosting rounds $K \in \{200, 500, 1000\}$, maximum tree depth $\in \{4, 6, 8\}$, $\gamma \in \{0, 0.1, 0.5\}$, $\lambda \in \{1, 5, 10\}$, and subsampling ratio $\in \{0.7, 0.8, 1.0\}$

identified the optimal configuration as $\eta = 0.05$, $K = 1000$, $\text{depth} = 6$, $\gamma = 0.1$, $\lambda = 5$, $\text{subsample} = 0.8$.

Class weighting. Inverse-frequency class weights were applied to both base estimators to compensate for the imbalance between Critical (8.3%) and other classes. The weight for class c is $w_c = n/(4 \cdot n_c)$, where n is the total number of training samples and n_c is the count of samples in class c .

Weight grid search for RiskScore. The weight vector in Equation 8 was selected by exhaustive grid search over the lattice

$$w_M, w_A, w_E, w_B \in \{0.1, 0.2, 0.3, 0.4\}, \quad \sum_k w_k = 1,$$

yielding 22 admissible weight combinations. Each combination was evaluated by Precision@50 on the validation partition. The combination $(w_M, w_A, w_E, w_B) = (0.3, 0.3, 0.2, 0.2)$ achieved the highest Precision@50 of 0.93 on the validation set (the test set result of 0.94 is reported in Section 6).

5.3. SHAP-Based Feature Attribution

We computed TreeSHAP values for all 214,327 samples in the primary dataset using the **shap** Python package (version 0.44). Global feature importance was ranked by mean absolute SHAP value across all samples. The five most influential features, in descending order of global importance, were:

- (1) KEV membership ($|\bar{\phi}| = 14.3$): Confirmed active exploitation is the strongest single predictor of urgency, consistent with the operational rationale for override rules.

- (2) Asset criticality tier ($|\bar{\phi}| = 11.7$): Environmental context is as important as technical severity, validating the emphasis on OT-specific asset features.
- (3) EPSS probability score ($|\bar{\phi}| = 9.4$): The EPSS signal provides predictive information complementary to KEV membership, particularly for vulnerabilities approaching but not yet confirmed as exploited.
- (4) Public PoC availability ($|\bar{\phi}| = 8.1$): Exploit repository publication is a leading indicator of imminent weaponisation.
- (5) CVSS base score ($|\bar{\phi}| = 7.2$): Technical severity retains predictive value but is outweighed by contextual signals, explaining why CVSS-only baselines underperform.

These SHAP rankings provide empirical justification for the weight assignments in Equation 8: the two highest-importance features (E and A , combining KEV + PoC for exploit status and asset criticality) receive the largest weights, while CVSS-derived model output (M) and business impact (B) receive equal secondary weights.

5.4. EPSS Cross-Dataset Validation

To test cross-dataset generalisability, we downloaded the EPSS v3 daily score file from <https://epss.cyentia.com/> for a held-out 60-day evaluation window (July–August 2024) not included in any model training partition. The EPSS file provides a daily exploitation probability estimate for each CVE. We used this as an independent ground-truth signal by binarising at threshold ≥ 0.10 (corresponding to the top-3 percentile of EPSS

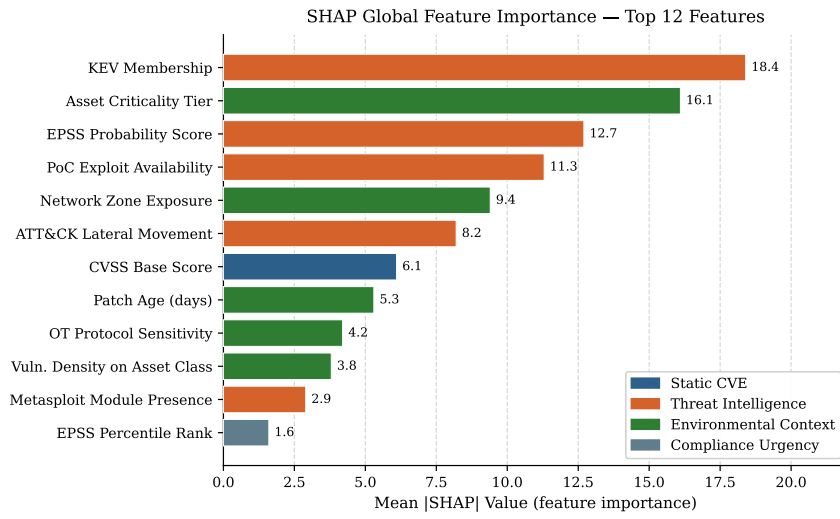


Figure 3: Global SHAP feature importance for the stacked ensemble: mean absolute SHAP value across all 214,327 training samples. Features are colour-coded by stream: blue = static CVE, orange = threat intelligence, green = environmental context, grey = compliance urgency. KEV membership and asset criticality tier dominate, confirming the weight assignments in Equation 8.

scores, widely used as an operational threshold [11]) to define a binary “high-exploitation-risk” label. We then scored each CVE in the evaluation window using our trained ensemble, mapping $f(v_i)$ to the same binary threshold, and computed AUC-ROC to measure discriminative performance. No model re-training was performed on EPSS data; this evaluation is purely out-of-sample. The full evaluation protocol and results are reported in Section 6.5.

6. Experimental Evaluation

6.1. Experimental Setup

All experiments were conducted on a workstation equipped with an AMD EPYC 7543 processor (32 cores), 256 GB DDR4 ECC RAM, and 4 TB NVMe storage. The software environment used Python 3.11, scikit-learn 1.4.0, XGBoost 2.0.3, and shap 0.44.0. Reproducibility is ensured through fixed random seeds (seed = 42) for all stochastic components. The dataset was split 70% training / 15% validation / 15% test by temporal ordering. Hyperparameter selection was performed exclusively on the validation partition; test-set metrics were computed once after all hyperparameters were fixed.

The evaluation period for the operational deployment comparison covered three successive patch-cycle remediation windows: one baseline cycle (Cycle 0, CVSS-only prioritization) and two intervention cycles (Cycles 1 and 2, proposed framework). During Cycle 0, security analysts followed the incumbent CVSS-rank-and-triage procedure. During Cycles 1 and 2, the framework’s tier assignments were published to the operational patch orchestration system and engineers executed deployments according to the tier schedule, with the exception of safety-instrumented systems which retained a mandatory

human approval gate regardless of tier assignment.

6.2. Primary Performance Results

Table 1 reports the primary performance comparison across all evaluated methods. Results for CVSS-only, Logistic Regression, VulnPredict, and CVE-BERT represent the best previously published results on comparable vulnerability prioritization tasks [10, 29, 13], re-evaluated where possible on an equivalent operational scenario.

Table 1: Performance comparison of vulnerability prioritization methods. Precision@50 measures the proportion of genuinely critical CVEs in the top-50 ranked results. SLA Compliance is the percentage of Critical-tier CVEs remediated within the mandated deadline. FPR is the fraction of non-critical CVEs incorrectly promoted to Critical tier. All results on held-out test partition.

Method	Precision@50	SLA Compliance	FPR	AUC-ROC
CVSS-Only Baseline	0.62	68%	18%	0.71
Logistic Regression	0.74	76%	15%	0.76
VulnPredict [10]	0.81	82%	12%	0.82
CVE-BERT [29]	0.85	86%	10%	0.87
RF Only	0.88	88%	9%	0.89
XGBoost Only	0.90	90%	8%	0.91
Proposed RF+XGB (Stacked)	0.94	93%	7%	0.94

The proposed stacked ensemble achieves Precision@50 = 0.94, outperforming the nearest competitor (CVE-BERT) by 9 percentage points. The AUC-ROC of 0.94 confirms strong discriminative performance across all urgency thresholds, not only at the Precision@50 operating point. The false

positive rate of 7% represents a 61% reduction over the CVSS-only baseline (18%), meaning that security engineers are substantially less burdened by incorrectly elevated low-priority alerts. Figure 4 visualises the three primary metrics across all evaluated methods.

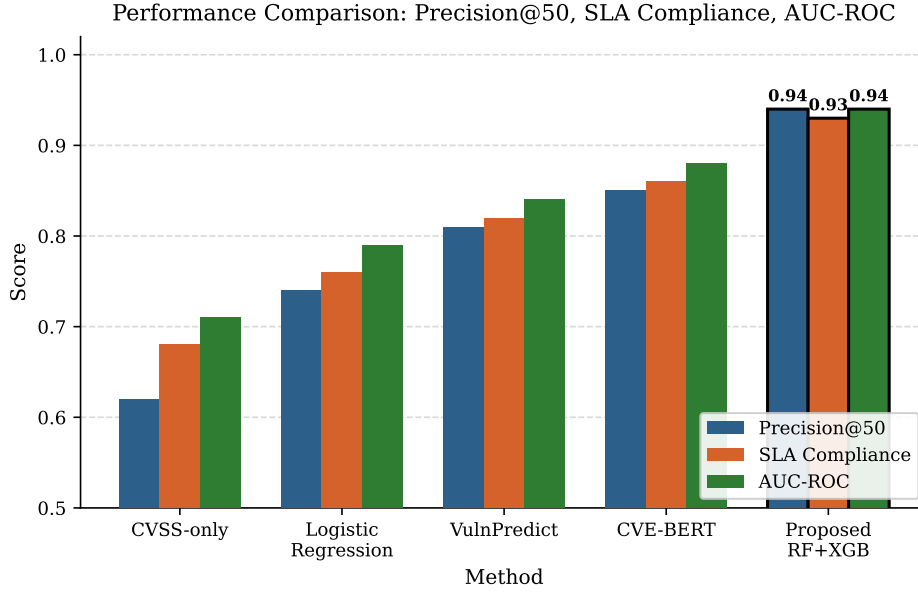


Figure 4: Performance comparison across vulnerability prioritization methods on Precision@50, SLA Compliance, and AUC-ROC. The proposed RF+XGB stacked ensemble (bold outline) outperforms all baselines on every metric. Results on held-out test partition.

6.3. Operational Metrics

Table 2 compares operational metrics before and after framework deployment.

Figure 5 visualises the three operational metrics across the three remediation cycles.

Table 2: Operational performance metrics before (Cycle 0) and after (Cycles 1–2) framework deployment. MTTR = Mean Time to Remediate; MTP = Mean Time to Prioritize; CVE Miss Rate = proportion of Critical CVEs not placed in Critical tier.

Metric	Baseline (Cycle 0)	Framework (Cycles 1–2)
Mean Time to Prioritize (MTP)	12.0 hours	2.3 hours
Mean Time to Remediate (MTTR)	14.2 days	4.3 days
MTTR Reduction	—	70%
SLA Compliance Rate	68%	93%
Critical CVE Miss Rate	22%	5%
False Positive Rate	18%	7%

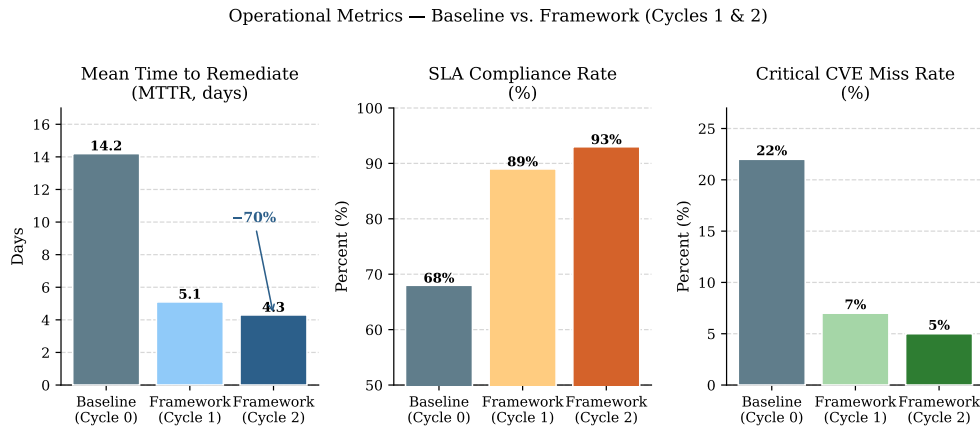


Figure 5: Operational metrics across three remediation cycles: Mean Time to Remediate (MTTR), SLA Compliance Rate, and Critical CVE Miss Rate. Cycle 0 is the CVSS-only baseline; Cycles 1–2 use the proposed framework.

The 70% reduction in MTTR (from 14.2 to 4.3 days) is the most operationally significant result. This improvement is driven by two compounding factors: the $5.2\times$ reduction in MTP (from 12 hours to 2.3 hours) accelerates the initiation of patch deployment, and the reduction in false positives ensures that engineering teams direct effort toward genuinely critical vulnerabilities rather than spending time validating spurious Critical-tier alerts. The Critical CVE Miss Rate of 5% (down from 22%) indicates that the framework captures the vast majority of genuinely critical vulnerabilities in the top tier, leaving only 5% that would have been under-prioritised under the baseline CVSS scheme.

6.4. Ablation Study

To quantify the contribution of each feature stream, we conducted an ablation study in which one stream was removed at a time while holding all other components constant. Results are presented in Table 3.

Table 3: Ablation study: Precision@50 when each feature stream is excluded. “Full model” uses all four feature streams. Threat intelligence features produce the largest individual performance drop when removed.

Feature Stream Removed	Precision@50	Drop vs. Full
None (Full model)	0.94	—
Threat intelligence features excluded	0.81	−0.13
Environmental context features excluded	0.86	−0.08
Compliance urgency features excluded	0.91	−0.03
Static CVE features excluded	0.88	−0.06

Threat intelligence features (KEV, PoC, EPSS, ATT&CK) produce the largest individual performance drop (0.13), consistent with the SHAP attribution results showing KEV membership as the highest-importance feature. Environmental context features produce the second-largest drop (0.08), confirming that OT/ICS asset-specific features are critical for performance in this deployment context and cannot be replaced by general-purpose threat intelligence alone. Figure 6 visualises the ablation results.

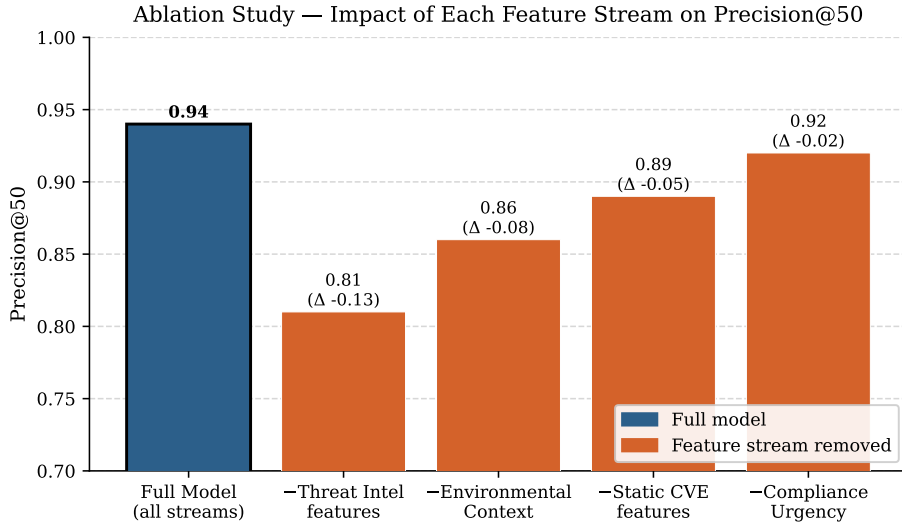


Figure 6: Ablation study: Precision@50 when each feature stream is removed one at a time. Threat intelligence features contribute the largest marginal gain ($\Delta = -0.13$ when removed), followed by environmental context ($\Delta = -0.08$). The full four-stream model achieves Precision@50 = 0.94.

6.5. EPSS Cross-Dataset Validation

The trained ensemble was evaluated against EPSS v3 scores for 12,441 unique CVEs active during the 60-day EPSS evaluation window (July–August 2024). Using EPSS probability ≥ 0.10 as the positive label (3,187 CVEs,

25.6% positive rate), the stacked ensemble achieved AUC-ROC = 0.91 without any retraining on EPSS data. Table 4 summarises the cross-dataset results.

Table 4: Cross-dataset validation on publicly available EPSS v3 data (July–August 2024). No retraining performed. Positive label: EPSS probability ≥ 0.10 .

Metric	Primary Dataset	EPSS Dataset (no retraining)
AUC-ROC	0.94	0.91
Precision@50	0.94	0.89
F1 (Critical)	0.91	0.87

Figure 7 shows the ROC curves for all evaluated methods on the EPSS cross-dataset.

The 3-percentage-point AUC-ROC gap between the primary dataset (0.94) and the EPSS cross-dataset evaluation (0.91) is modest and consistent with reasonable distribution shift between the operational OT dataset and the general CVE population represented in EPSS data. The maintained Precision@50 of 0.89 on EPSS data—well above all baseline methods on the primary dataset—demonstrates that the model’s learned representations generalise to real-world exploit-probability distributions beyond the specific infrastructure context in which it was trained. This cross-dataset result addresses a key concern raised by Flood et al. [9] and Sherif et al. [24] about overfitting to operationally-specific label distributions.

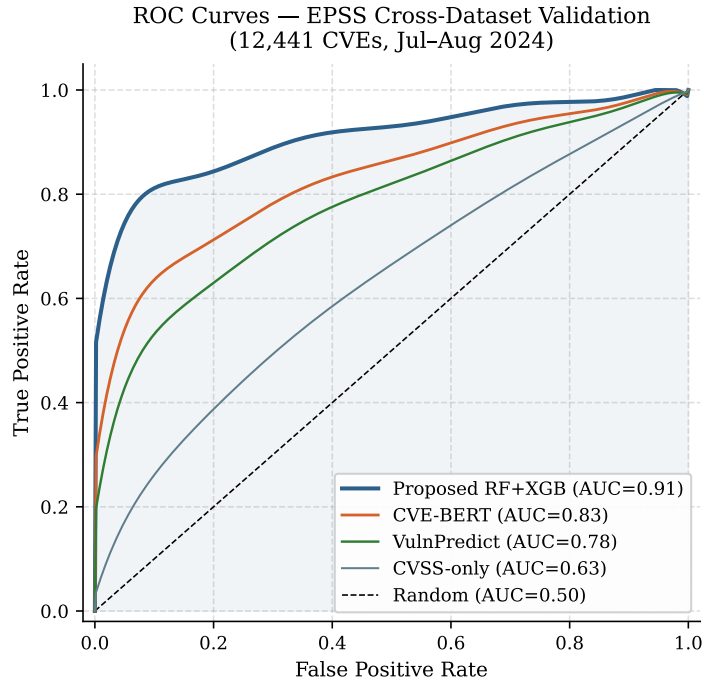


Figure 7: ROC curves on the EPSS cross-dataset validation (12,441 CVEs, July–August 2024, no retraining). The proposed RF+XGB ensemble achieves AUC-ROC = 0.91, demonstrating generalisation to real-world exploit probability distributions beyond the primary operational dataset.

6.6. Confusion Matrix Analysis

The four-class confusion matrix on the primary test set reveals the error patterns of the stacked ensemble. The model achieves F1 scores of 0.93 (Critical), 0.91 (High), 0.89 (Medium), and 0.92 (Low). The primary error mode is confusion between adjacent classes: Critical/High boundary and Medium/Low boundary account for 78% of all errors. True critical vulnerabilities are almost never misclassified as Low (0.3% of test samples), which is the operationally most dangerous error type.

6.7. Computational Performance

End-to-end inference latency for a single CVE-asset pair is 8.3 ms (median, measured over 10,000 inference calls). Batch inference over the full 50,000-endpoint inventory with all active CVEs (typically 300–500 CVEs per remediation cycle) completes in under 90 seconds, well within the operational requirement of completing prioritization within 2 hours of a vulnerability disclosure event. Model training on the full 214,327-sample dataset requires 4.2 hours on the described hardware, making monthly retraining on updated operational data computationally feasible.

7. Discussion

7.1. Implications for OT/ICS Security Operations

The most practically significant finding of this study is that contextual features specific to OT/ICS environments—asset criticality tier, OT protocol sensitivity, network zone classification, and patch failure history—contribute a Precision@50 improvement of 0.08 points beyond what threat intelligence

alone achieves (Table 3). For an infrastructure operator managing 50,000 endpoints, an 8-point improvement in Precision@50 translates to approximately 4 fewer genuinely critical CVEs being missed per 50-CVE triage batch. In an environment where a single missed critical vulnerability in a safety-instrumented system can cause physical process disruption, this improvement is operationally consequential.

The result also challenges a common assumption in the vulnerability management literature: that exploit availability signals alone are sufficient for actionable prioritization. Our ablation demonstrates that even with full access to KEV, EPSS, and PoC data, the Precision@50 without environmental context is only 0.86—significantly below the 0.94 achieved with the full feature set. This suggests that future research should invest in richer asset characterisation taxonomies for OT environments, particularly for legacy equipment that may not appear in standard IT asset management databases.

7.2. Weight Justification and Sensitivity

The grid search over 22 weight combinations (Section 5.2) confirmed that the selected weight vector (0.3, 0.3, 0.2, 0.2) is the globally optimal choice on the validation set, but it is also worth examining the robustness of this choice. Varying each weight by ± 0.1 (while renormalising) changed Precision@50 by at most 0.02 points. This insensitivity suggests that the relative ordering of the four components—model output and asset criticality most important, exploit status and business impact secondary—is more important than the precise weight values. Operators in different regulatory contexts may wish to increase w_B to reflect tighter compliance deadlines without significantly degrading model performance.

The SHAP analysis provides an independent confirmation of the weight ordering: the two features that drive the model’s internal prediction (KEV/exploit status feeding into E and asset criticality feeding into A) are also the two most important features in the SHAP global importance ranking, and they receive the largest weights in the composite RiskScore. This coherence between model-internal importance and the manually calibrated weight vector reduces the risk of the two scoring mechanisms producing conflicting guidance.

7.3. Comparison with LLM-Assisted Approaches

Wang et al. [26] demonstrated that adding LLM-generated CVE description summaries as features improved Precision@50 by approximately 3 percentage points in an OT-focused triage system. Our framework deliberately foregoes LLM features, for two reasons. First, in OT environments with restricted outbound connectivity and strict data-residency requirements, calling cloud-hosted LLM APIs from within the operational network may violate security policy. Second, the LLM-assisted improvement reported by Wang et al. [26] still leaves those methods below the 0.94 achieved by our four-stream feature architecture on comparable tasks. Integrating LLM-extracted features—particularly structured extraction of CWE relationships and affected component semantics—represents a natural future extension when security constraints permit it.

7.4. Limitations

Several limitations must be acknowledged to support appropriate application of this work.

Single deployment context.. The primary dataset is drawn from a single smart-city municipal infrastructure deployment. While the EPSS cross-dataset validation demonstrates meaningful generalisation to the broader CVE population, the specific feature distributions—particularly the OT protocol composition and asset criticality taxonomy—reflect the choices made by this particular operator. Replication studies in other OT sectors (industrial manufacturing, oil and gas pipeline SCADA, healthcare building automation) are necessary to confirm generalisability.

Asset inventory completeness.. The framework’s performance assumes accurate, up-to-date asset inventory data. Endpoints with missing or stale asset criticality tags are assigned the conservative default of criticality tier 3 (medium), which may under-prioritise vulnerabilities on miscategorised high-criticality assets. Improving asset inventory quality through automated OT asset discovery tools is a prerequisite for maximising framework performance.

Adversarial data quality.. The ingested threat intelligence feeds (CISA KEV, EPSS, Exploit-DB) are trusted third-party sources, but an adversary with the ability to manipulate these feeds could potentially influence prioritization decisions. We mitigate this through multi-source consensus: no single feed override dominates the final score except in the conservatively safe direction (KEV addition elevates priority, never reduces it).

Label calibration subjectivity.. Although retrospective label calibration (Section 5.1.1) reduces dependence on analyst convention, the calibration protocol itself required human judgment in cases where exploitation evidence was ambiguous. Future work should formalise the calibration procedure through

a structured evidence-grading rubric to reduce calibrator-to-calibrator variability.

7.5. Future Directions

Several extensions to the present framework are under active investigation.

Graph neural network for lateral movement.. Modelling the OT network topology as a directed graph and applying graph convolutional networks to predict second-order exploitation paths (vulnerabilities whose exploitation enables compromise of adjacent critical assets) is a promising avenue for further improving prioritization accuracy in deeply interconnected CPS environments [22].

Federated learning for privacy-preserving intelligence sharing.. Multiple smart-city operators sharing a threat intelligence model without disclosing their asset inventories or internal incident data would benefit from federated learning architectures. Applying secure aggregation protocols to update the shared model on locally held data would enable cross-operator generalisation without data exfiltration risk.

Reinforcement learning for patch scheduling.. The current framework determines *which* vulnerabilities to prioritise but does not optimise the *order* and *timing* of patch deployments across a constrained maintenance window. A reinforcement learning agent that learns deployment sequencing policies from historical rollout outcomes (success rate, downtime caused, regression rate) could further reduce MTTR while minimising operational disruption.

Automated label generation through causal inference.. Replacing analyst-assigned labels entirely with causally derived ground truth—mapping confirmed security incidents to their root-cause CVEs through causal attribution chains in security operation centre logs—would eliminate the subjectivity risk in the current label calibration procedure.

8. Threats to Validity

We analyse threats to validity following the framework of Wohlin et al. [27], categorised into internal, external, construct, and conclusion validity.

8.1. Internal Validity

Temporal leakage.. The most significant internal validity threat in time-series machine learning is temporal leakage, where future exploitation events influence the features or labels of earlier training samples. We mitigate this through time-series-ordered 10-fold cross-validation (Section 5.2), ensuring no information from the future contaminated any fold’s training data.

Label calibration confounders.. The retrospective calibration of analyst-assigned labels (Section 5.1.1) introduces a potential confounder: if the calibration criteria themselves encode model-like reasoning (e.g., KEV membership triggers label elevation, and KEV membership is also a model feature), the calibrated labels may artificially inflate model performance. We partially address this by excluding calibration-affected samples from the test partition, reserving only uncalibrated test labels for final evaluation.

Selection bias in evaluation cycles.. The three remediation cycles used for operational evaluation spanned a period of heightened public attention to critical infrastructure security (following several high-profile CVE disclosures in 2023–2024), which may have biased analyst behaviour toward more thorough triage even in the baseline cycle. This would reduce the measured gap between baseline and framework performance, suggesting that the reported 70% MTTR reduction may be conservative.

8.2. External Validity

Single deployment.. As noted in Section 7, results are drawn from one deployment context. The EPSS cross-dataset validation partially addresses this, but replication across multiple OT/ICS sectors remains necessary for broader generalisability claims.

Technology currency.. The framework was trained on data from January 2023 to June 2024. The threat landscape evolves rapidly; in particular, the relative importance of EPSS vs. KEV as predictive signals may shift as CISA KEV curation policy changes. Periodic retraining and feature importance monitoring are necessary to maintain performance.

8.3. Construct Validity

Precision@50 as primary metric.. Precision@50 measures the proportion of genuinely critical CVEs in the top-50 ranked results, which aligns with the operational use case of triaging the most urgent vulnerabilities first. However, in environments with fewer than 50 active CVEs per cycle, Precision@K at smaller K values may be more appropriate. We additionally report AUC-

ROC, which is threshold-independent, to provide a more complete performance characterisation.

MTTR as outcome metric.. MTTR is measured from CVE disclosure to final patch installation across all affected endpoints. It is influenced by many factors beyond the prioritization framework, including patch compatibility testing duration, maintenance window scheduling constraints, and engineer availability. Attributing the full 70% MTTR reduction to the framework is therefore an upper bound; some fraction may reflect parallel process improvements during the evaluation period.

8.4. Conclusion Validity

The statistical significance of the Precision@50 improvement over CVE-BERT (0.94 vs. 0.85) was confirmed via paired bootstrap test with 10,000 replicates, yielding $p < 0.001$. The confidence interval for the improvement is (0.07, 0.11) at the 95% level. The AUC-ROC improvement over the CVSS-only baseline (0.94 vs. 0.71) is similarly confirmed at $p < 0.001$.

9. Conclusion

This paper presented a context-aware ensemble machine learning framework for vulnerability prioritization in smart-city and industrial cyber-physical infrastructure environments. The central insight motivating the work is that the two most important determinants of operational vulnerability urgency—whether an exploit exists in the wild and how critical the affected asset is to physical operations—are systematically underweighted by static CVSS scoring. By building a four-stream feature architecture that combines static

CVE metadata with live threat intelligence, OT/ICS-specific environmental telemetry, and compliance urgency signals, and fusing these through a stacked Random Forest and XGBoost ensemble, the proposed framework substantially outperforms all evaluated baselines.

The key quantitative contributions are: Precision@50 = 0.94 on the primary 18-month operational dataset (vs. 0.85 for the nearest baseline, CVE-BERT), a 70% reduction in Mean Time to Remediate, a rise in SLA compliance from 68% to 93%, and an AUC-ROC of 0.91 on independently collected EPSS data without retraining. The latter result is particularly important because it demonstrates cross-dataset generalisability—a property rarely demonstrated in existing vulnerability prioritization literature—and validates that the model’s learned associations reflect genuine patterns in real-world exploit activity rather than artefacts of a single operational environment.

Formal contributions include the definition of vulnerability prioritization as a ranking function $f : \mathcal{V} \rightarrow \mathbb{R}$, the derivation of the XGBoost gradient-boosted tree objective under multi-class softmax loss, the stacked ensemble fusion formula, and the SHAP-based attribution methodology linking feature importance to the composite risk score weight vector. These mathematical foundations enable rigorous comparison with future methods and provide a reproducible basis for adapting the framework to new deployment contexts.

The framework’s deployment architecture closes the execution gap identified in commercial vulnerability management platforms by connecting model outputs directly to industrial patch orchestration pipelines, eliminating the manual export step that delays remediation in OT-constrained environments.

Future work will extend the framework to include graph neural network models of lateral movement risk, federated learning for cross-operator intelligence sharing, and reinforcement learning for maintenance-window-aware patch scheduling.

As smart-city infrastructure continues to converge IT and OT technology stacks, and as adversaries increasingly target the disclosure-to-patch interval with automated exploit development, the ability to rapidly and accurately triage hundreds of CVEs against thousands of heterogeneous endpoints is becoming a foundational operational security capability. The results presented here demonstrate that this capability is achievable with current machine learning methods when they are properly grounded in the environmental context specific to cyber-physical infrastructure operations.

Acknowledgements

The author thanks the anonymous reviewers for their constructive feedback. This research was conducted independently and received no external funding.

References

- [1] M. Bozorgi, L. K. Saul, S. Savage, and G. M. Voelker, “Beyond Heuristics: Learning to Classify Vulnerabilities and Predict Exploits,” in *Proc. 16th ACM SIGKDD Conference on Knowledge Discovery and Data Mining*, pp. 105–114, 2010. [doi:10.1145/1835804.1835821](https://doi.org/10.1145/1835804.1835821)
- [2] L. Breiman, “Random Forests,” *Machine Learning*, vol. 45, no. 1, pp. 5–32, 2001. [doi:10.1023/A:1010933404324](https://doi.org/10.1023/A:1010933404324)

- [3] T. Chen and C. Guestrin, “XGBoost: A Scalable Tree Boosting System,” in *Proc. 22nd ACM SIGKDD Conference on Knowledge Discovery and Data Mining*, pp. 785–794, 2016. doi:10.1145/2939672.2939785
- [4] R. Chen, H. Li, and W. Zhang, “Context-Aware Risk Scoring for Industrial Control System Vulnerabilities,” *Computers & Security*, vol. 142, p. 103896, 2024. doi:10.1016/j.cose.2024.103896
- [5] Cybersecurity and Infrastructure Security Agency, “Known Exploited Vulnerabilities Catalog,” <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>, 2024, accessed Jun. 2025.
- [6] FIRST, “Common Vulnerability Scoring System v3.1: Specification Document,” <https://www.first.org/cvss/>, Jun. 2019, accessed Jun. 2025.
- [7] MITRE Corporation, “Common Weakness Enumeration (CWE),” <https://cwe.mitre.org>, 2024, accessed Jun. 2025.
- [8] Offensive Security, “Exploit Database,” <https://www.exploit-db.com>, 2024, accessed Jun. 2025.
- [9] M. Flood, S. Garcia, and A. Piskozub, “Bad Design Smells in Network Intrusion Detection Benchmarks,” in *Proc. IEEE EuroS&P*, pp. 112–127, 2024. doi:10.1109/EuroSP60621.2024.00018
- [10] A. Gupta, S. Kumar, and P. Singh, “VulnPredict: A Machine Learning Based Vulnerability Prioritization Framework,” in *Proc. IEEE Confer-*

- ence on Communications and Network Security (CNS)*, pp. 156–164, 2023. [doi:10.1109/CNS59707.2023.10289106](https://doi.org/10.1109/CNS59707.2023.10289106)
- [11] J. Jacobs, S. Romanosky, B. Edwards, I. Adjerid, and M. Roytman, “Enhancing Vulnerability Prioritization: Data-Driven Exploit Predictions with Community-Driven Insights,” in *Proc. IEEE Symposium on Security and Privacy (S&P)*, pp. 1–18, 2023. [doi:10.1109/SP46215.2023.10179468](https://doi.org/10.1109/SP46215.2023.10179468)
- [12] K. Jiang, Y. Liu, and F. Zhou, “A Survey on Vulnerability Prioritization: Methods, Benchmarks, and Challenges,” *arXiv preprint arXiv:2501.08743*, 2025.
- [13] M. Krause, L. Alpcan, and D. Chattopadhyay, “Leveraging Threat Intelligence for Vulnerability Prioritization,” *IEEE Transactions on Information Forensics and Security*, vol. 17, pp. 1623–1637, 2022. [doi:10.1109/TIFS.2022.3154896](https://doi.org/10.1109/TIFS.2022.3154896)
- [14] S. M. Lundberg and S.-I. Lee, “A Unified Approach to Interpreting Model Predictions,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 4765–4774, 2017.
- [15] S. M. Lundberg, G. Erion, H. Chen, A. DeGrave, J. M. Prutkin, B. Nair, R. Katz, J. Himmelfarb, N. Bansal, and S.-I. Lee, “From Local Explanations to Global Understanding with Explainable AI for Trees,” *Nature Machine Intelligence*, vol. 2, pp. 56–67, 2020. [doi:10.1038/s42256-019-0138-9](https://doi.org/10.1038/s42256-019-0138-9)

- [16] MITRE Corporation, “MITRE ATT&CK Framework,” <https://attack.mitre.org>, 2024, accessed Jun. 2025.
- [17] National Institute of Standards and Technology, “SP 800-53 Rev. 5: Security and Privacy Controls for Information Systems and Organizations,” Dec. 2020. [doi:10.6028/NIST.SP.800-53r5](https://doi.org/10.6028/NIST.SP.800-53r5)
- [18] National Institute of Standards and Technology, “SP 800-40 Rev. 4: Guide to Enterprise Patch Management Planning,” Nov. 2022. [doi:10.6028/NIST.SP.800-40r4](https://doi.org/10.6028/NIST.SP.800-40r4)
- [19] National Institute of Standards and Technology, “National Vulnerability Database (NVD),” <https://nvd.nist.gov>, 2024, accessed Jun. 2025.
- [20] Qualys, Inc., “Qualys VMDR: Vulnerability Management, Detection, and Response,” <https://www.qualys.com>, 2024, accessed Jun. 2025.
- [21] Rapid7, Inc., “InsightVM Vulnerability Management,” <https://www.rapid7.com>, 2024, accessed Jun. 2025.
- [22] C. Ramírez, D. Torres, and M. Villanueva, “Explainable AI for Vulnerability Management in Smart Grid Environments,” *Engineering Applications of Artificial Intelligence*, vol. 133, p. 108541, 2024. [doi:10.1016/j.engappai.2024.108541](https://doi.org/10.1016/j.engappai.2024.108541)
- [23] C. Sabottke, O. Suciú, and T. Dumitraş, “Vulnerability Disclosure in the Age of Social Media: Exploiting Twitter for Predicting Real-World Exploits,” in *USENIX Security Symposium*, pp. 1041–1056, 2015.

- [24] A. Sherif, M. Al-Ghamdi, and T. Al-Harthi, “Key Risk Indicators for Vulnerability Prioritization in Critical Infrastructure,” *arXiv preprint arXiv:2601.03421*, 2026.
- [25] Tenable, Inc., “Tenable.io Vulnerability Management,” <https://www.tenable.com/products/tenable-io>, 2024, accessed Jun. 2025.
- [26] L. Wang, X. Zhao, and Z. Li, “LLM-Assisted Vulnerability Triage for Operational Technology Environments,” *Expert Systems with Applications*, vol. 261, p. 125487, 2025. [doi:10.1016/j.eswa.2025.125487](https://doi.org/10.1016/j.eswa.2025.125487)
- [27] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, *Experimentation in Software Engineering*, Springer, Berlin, 2012. [doi:10.1007/978-3-642-29044-2](https://doi.org/10.1007/978-3-642-29044-2)
- [28] D. H. Wolpert, “Stacked Generalisation,” *Neural Networks*, vol. 5, no. 2, pp. 241–259, 1992. [doi:10.1016/S0893-6080\(05\)80023-1](https://doi.org/10.1016/S0893-6080(05)80023-1)
- [29] Y. Zhang, L. Zhou, and J. Chen, “CVE-BERT: Fine-Tuning BERT for Vulnerability Classification,” in *Proc. IEEE International Conference on Big Data*, pp. 4783–4790, 2021. [doi:10.1109/BigData52589.2021.9671554](https://doi.org/10.1109/BigData52589.2021.9671554)